# ISEAGE Competition Docs

Technical Defense & Operational Guidelines

# White Team

Technical & Defensive Architecture Document

# Network Architecture

## Active Directory

Windows Server acting as the core authentication and domain management system. Strictly isolated from public internet exposure.

## Management Server

Hosts the Admin UI using a Flask framework. Acts as the control plane with strong rate limiting and session security controls.

## WWW Server

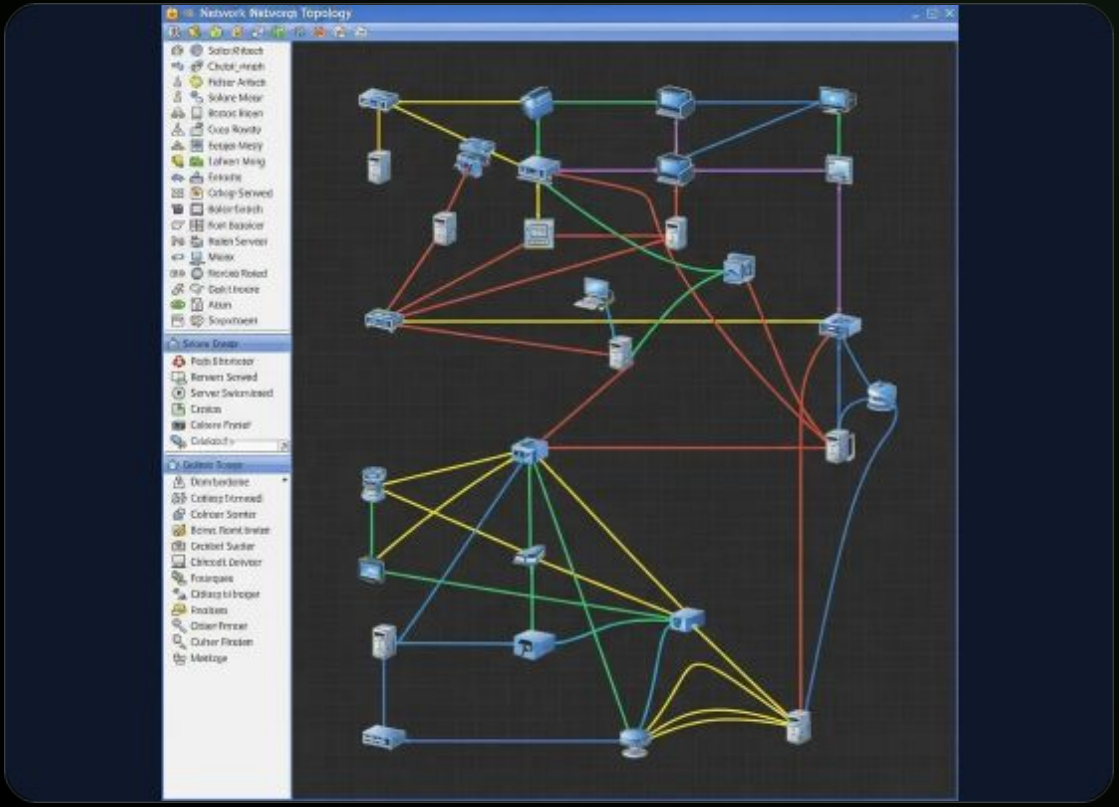
AlmaLinux public web host handling external traffic. Hardened with firewalld, SELinux, and strict directory permissions.

# Public Services Overview

| SERVICE | HOST URL | PORT | DESCRIPTION |
|---|---|---|---|
| WWW | www.team40.isucdc.com | 80 | Public Website |
| ADMIN | admin.team40.isucdc.com | 80 | Admin Panel |
| MGMT | mgmt.team40.isucdc.com | 5000 | Backend API (Internal) |
| AD LDAP/S | ad.team40.isucdc.com | 389 / 636 | LDAP & Secure LDAP |
| AD RDP | ad.team40.isucdc.com | 3389 | Restricted RDP |

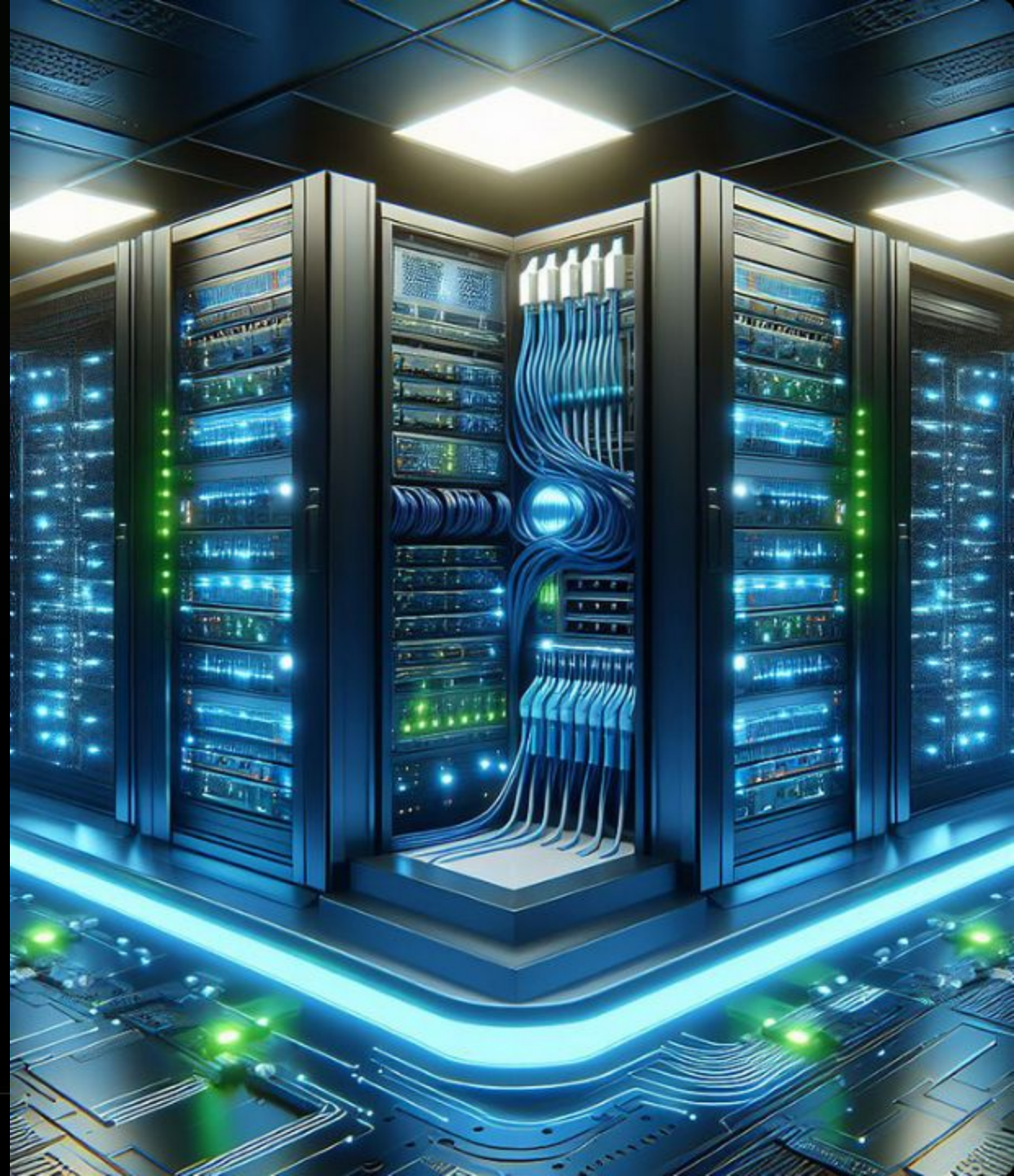
# Active Directory Hardening

- **Account Lockout Policy:** Enforced at 5 failed attempts with a 15-minute lockout duration.
- **Password Complexity:** Minimum length set to 12 characters with strict complexity enabled.
- **Network Restrictions:** SMB traffic blocked from the internet; RDP restricted to Admin groups with NLA.
- **Audit Logging:** Detailed tracking enabled for both Success and Failure logon events.
- **Windows Firewall:** Active with strict inbound/outbound rules limiting unnecessary lateral movement.



# MGMT Server Security

- **Port Restrictions:** Only port 80 exposed publicly; backend port 5000 is internal only. SSH is not publicly exposed.
- **Session Security:** Implemented SESSION_COOKIE_SECURE, HTTPONLY, and SameSite=Lax. Session regeneration on login.
- **Strict Security Headers:** Enforced X-Frame-Options: DENY, X-Content-Type-Options: nosniff, and strong CSP.
- **App Level Protection:** IP-based login rate limiting, input length validation, and full CSRF protection implemented.



# WWW Server (AlmaLinux)

- **Firewall Configuration:** firewalld active. Allows only required ports (80 HTTP, 443 HTTPS, restricted 22 SSH).
- **Intrusion Prevention:** Fail2ban installed and actively banning malicious IP patterns.
- **Access Controls:** SELinux set to enforcing mode. Web directory permissions strictly hardened.
- **Database Security:** MySQL configured with bind-address pointing to localhost only.
- **Authentication:** SSH key authentication recommended; password auth severely restricted.

# Monitoring & Backup Strategy

## Monitoring & Logging

- **Windows Event Logs:** Tracking logon failures and system events.
- **Flask Logs:** Monitoring failed login attempts and rate limit triggers.
- **Web Access Logs:** Tracking standard HTTP traffic and errors.
- **Backend Auditing:** Capturing error logs for API interactions.

## Automated Backups

- **AD Server:** Daily system state and critical data backups via Task Scheduler.
- **MGMT Server:** Full backup every 30 minutes stored locally in C:\Backups\Admin.
- **WWW Server:** Daily tar archive backups stored in /backups with a 7-day retention policy via Cron.

# White Team: Hardening Summary

## Identity & Access

Mitigated Brute Force attacks and weak passwords through strict account lockouts, 12-char requirements, and IP-based rate limits.

## Application Sec

Prevented Session Hijacking, CSRF, XSS, and SQL Injection by enforcing secure cookies, input validation, and ORM security.

## Network Defenses

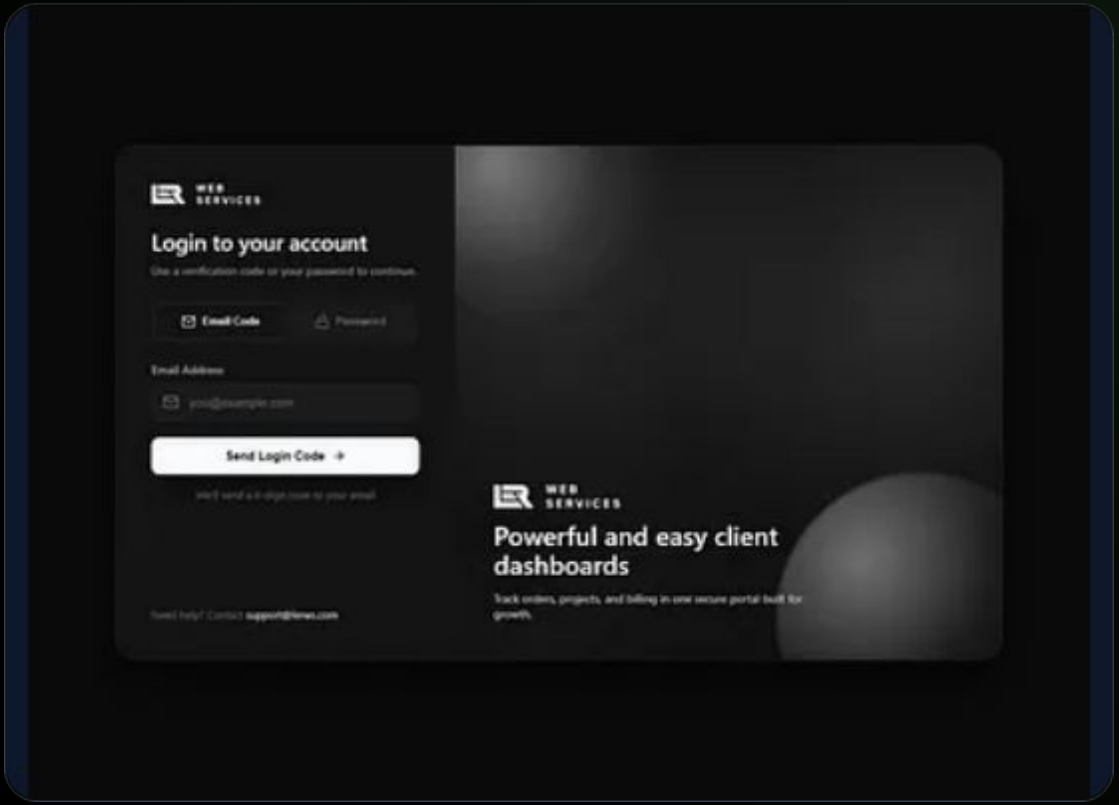
Blocked SMB internet exposure, prevented RDP abuse, and mitigated lateral movement via strict firewalld and Windows Firewall rules.

# Green Team

User & Operational Documentation

# Access & Admin Usage

- **Public Access:** The main website is available at www.team40.isucdc.com.
- **Admin Portal:** Login interface located at admin.team40.isucdc.com/login.
- **Admin Capabilities:** Once logged in, administrators can manage vehicles, view system status, and update capacities.
- **Password Changes:** Must be performed on the AD Server via Ctrl + Alt + End. Passwords must be 12+ characters and complex.



# Incident Response & Recovery

## 1. Detect & Analyze

If compromise is suspected, immediately check Windows Event Logs and Flask login attempts for anomalous behavior or unauthorized access.

## 2. Containment

Swiftly disable any affected or suspicious accounts to prevent further lateral movement across the network infrastructure.

## 3. Recovery

Restore the MGMT Server from C:\Backups\Admin\ or the WWW Server using the command tar -xzf backupfile.tar.gz.

# Image Sources

https://media.easy-peasy.ai/27feb2bb-aeb4-4a83-9fb6-8f3f2a15885e/d49ce12f-4b77-41f2-894e-a55c118337f6_medium.webp

Source: easy-peasy.ai

---

https://img.pikbest.com/origin/10/25/31/50QplkbEsTdhK.jpg!sw800

Source: pikbest.com

---

https://www.offsec.com/app/uploads/2020/03/kali-customization.png

Source: www.offsec.com

---

https://cdn.dribbble.com/userupload/46489957/file/8aec38c91402def4419db90e112d742b.png?format=webp&resize=400x300&vertical=center

Source: dribbble.com